

从单机权限到 AI 模型与知识保护

内容生产流程

拆章节 -> 每章调用 Codex 生成正文 -> 每章调用 GPT Images2 生成配图 -> 汇总排版 -> 输出 PDF。

1. 单机权限：安全从“这台机器归谁管”开始

早期安全的核心问题很朴素：谁能登录这台机器，谁能读写本地文件，谁能安装程序、修改配置、提升权限。管理员、普通用户、服务账号构成了最基本的权限边界。这个阶段的重点是账号、密码、本地组、文件 ACL 和系统审计。

但单机权限并没有消失。今天的终端仍然是身份、数据和任务链路的入口。开发者电脑、运维跳板机、员工笔记本一旦失守，攻击者就可能拿到浏览器会话、SSH Key、云凭证和内部系统访问能力。

图像提示：一台现代工作站，屏幕上叠加本地账号、文件权限、SSH Key 和浏览器会话的安全边界，写实科技风，清晰信息图。

2. 网络边界：从机房防火墙到组合攻击面

企业上网、服务器入站、内外网隔离、防火墙策略，曾经定义了很长一段时间的安全主战场。只要守住入口，默认内部网络可信，这是传统网络安全的基本假设。

云、移动办公、SaaS 和 API 普及后，边界被拆散了。今天的网络边界不只是 IP 和端口，而是 API、设备、身份、供应链、运行时和第三方集成的组合面。攻击也不再只从“打穿防火墙”开始，而可能从一个泄露 Token、一个开放对象存储桶、一个未校验 Webhook 或一个依赖包开始。

图像提示：传统防火墙边界逐渐碎裂，变成 API、设备、身份、供应链、运行时节点组成的网络拓扑，冷静企业安全风格。

3. Web 安全：页面漏洞扩展为业务流风险

Web 安全曾经最容易被理解为漏洞清单：SQL 注入、XSS、CSRF、文件上传、越权访问。它们仍然重要，但真正的风险已经扩展到业务流本身。攻击者更关心如何绕过审批、滥用接口、批量枚举、接管会话、自动化薅取权益，或者把插件和第三方脚本变成数据外泄通道。

所以 Web 安全不能只停留在扫描器和 WAF。它需要和身份、风控、审计、数据分级、API 治理一起工作。尤其当 AI Agent 可以自动浏览网页、调用后台接口、读写文件时，Web 不再只是用户界面，而是 Agent 执行动作的工作台。

图像提示：浏览器窗口中展示登录、API、插件、自动化脚本和数据流，旁边标注业务流风险，专业信息图，白底高对比。

4. 云身份：默认控制平面

进入云时代后，身份成为事实上的控制平面。谁能 Assume Role，谁能创建密钥，谁能访问对象存储，谁能改安全组，谁能跨账号部署资源，往往比某台服务器本身更关键。云环境里的风险也常常来自权限漂移、长期密钥暴露、过宽角色、跨账号信任和 CI/CD 凭证泄露。

云身份的治理重点，是把权限从“能不能登录机器”升级为“能不能代表某个主体操作某类资源”。最小权限、短期凭证、条件访问、资源标签、审计日志和权限边界，构成了云安全的基础。

图像提示：云控制平面中的 IAM、角色、短期凭证、跨账号访问和审计日志连接到计算与数据资源，现代云安全架构图。

5. Zero Trust：持续验证替代默认信任

Zero Trust 的价值不在口号，而在执行层：不因为你在内网就信任你，不因为你登录过一次就永久信任你，不因为你是某个部门的人就默认给你全部权限。每一次访问都要结合身份、设备、位置、会话、资源敏感度和行为上下文进行判断。

在实践中，Zero Trust 更像一套纪律：强身份、设备可信、最小权限、分段访问、持续评估、完整审计。它把过去一次性的准入控制，变成贯穿整个会话和操作过程的动态决策。

图像提示：用户、设备、应用、数据之间有动态策略引擎逐次校验访问请求，表达持续验证和最小权限，清爽企业图形风。

6. AI Agent 身份：谁在替人行动

AI Agent 的出现，把安全问题继续向前推了一步。过去系统主要判断“人是谁”，现在还要判断“这个 Agent 是谁创建的、代表谁、能做什么、能持续多久、能不能被撤销”。Agent 不是普通 API Key，也不应该混用人的全部权限。

一个可控的 Agent 身份需要独立标识、授权范围、任务上下文、工具白名单、数据访问边界、审计链路和撤销机制。它可以替人执行任务，但不能无限继承人的身份，也不能在缺少上下文时自行扩大权限。

图像提示：一个 AI Agent 作为独立身份站在人类用户与工具系统之间，权限边界、任务授权、审计链和撤销按钮清晰可见。

7. AI 模型与知识保护：新资产边界

AI 时代的新资产不只有模型权重。提示词、系统指令、RAG 知识库、企业文档、工具调用记录、对话历史、评测集和业务语料，都会影响模型行为，也都有可能泄露业务能力。保护模型，本质上是在保护知识、意图和执行路径。

因此，安全边界最终从“谁能访问系统”演进为“谁能携带什么知识，以什么身份，替谁执行什么动作”。未来的安全体系必须同时治理身份边界、知识边界和行动边界。人、应用、Agent、模型和工具都要可区分、可授权、可审计、可撤销。

图像提示：模型、RAG 知识库、提示词、业务文档和工具调用记录构成新的资产边界，中心是受保护的 AI 系统，精致信息图。

汇总判断

安全的演进不是旧问题被新问题替代，而是边界不断外移、主体不断增多、资产不断抽象。单机权限仍是入口，网络边界仍是基础，Web 安全仍是主战场，云身份成为控制平面，Zero Trust 成为执行纪律，而 AI Agent 身份与模型知识保护，正在成为下一轮企业安全的核心命题。